



DAQAI

Private Limited

ICT PROCUREMENT GUIDE

A practical framework
for procurement decision-
makers in Pakistan

3,000+

Vendors globally

43

Avg tools per org

\$10.2M

Avg breach cost

THE DEFINITIVE GUIDE

How to Choose a Cybersecurity Provider

A Framework for ICT Procurement
Decision-Makers in Pakistan

WHAT YOU WILL LEARN

- 8-step vendor evaluation framework
- Pakistan-specific risk considerations
- Red flags that expose bad vendors
- Scoring matrix and RFP checklist
- Questions every buyer must ask

WRITTEN FOR

- CIOs & IT Directors
- Head of Procurement
- CISO & Security Managers
- Government IT Officers

— WHY THIS GUIDE EXISTS

Cybersecurity procurement is broken — and it is costing organisations dearly.

Every year, organisations in Pakistan and across the region spend significant budget on cybersecurity products and services — and yet breaches continue to rise. The problem is rarely that organisations are not spending. It is that they are spending on the wrong things, selected through the wrong process, from the wrong providers.

3,000+

Cybersecurity vendors competing globally

43

Avg. security tools per enterprise

\$10.2M

Average cost of a breach in 2025

35.5%

Breaches caused by third parties

The Pakistan Context

Pakistan ranks 14th in Asia-Pacific for cyber vulnerabilities. DDoS attacks, ransomware, Business Email Compromise, and state-sponsored intrusions are all on the rise. The 2025 amendments to PECA have established the National Cyber Crime Investigation Agency (NCCIA) and are driving new regulatory expectations — but enforcement gaps remain significant.

Most critically: cybersecurity is not yet embedded in procurement processes. Research shows that IT supply chain security is routinely overlooked in public sector and enterprise procurement in Pakistan — creating systemic vulnerabilities that attackers actively exploit.

ABOUT THIS GUIDE

What this guide will give you

A structured 8-step framework for evaluating and selecting cybersecurity providers. Specific questions to ask vendors. Red flags to watch for. A scoring matrix you can use in your own procurement process. And a clear-eyed view of what good cybersecurity provision actually looks like — so you can tell it apart from what vendors claim.

BEFORE YOU EVALUATE VENDORS

Step 1 — Know What You Actually Need

1

Define Your Requirements Before Approaching Any Vendor

The most common procurement mistake is going to market before internal alignment is complete.

Before you speak to a single vendor, you need clear answers to four questions. Most procurement failures begin with skipping this step — and ending up with solutions that address the wrong problem.

What are your most critical assets and data?

List the systems, data, and processes that would cause the greatest harm if compromised. Prioritise these — not everything can be equally protected, and your budget will force trade-offs. Start with what matters most.

What are your real threats?

Generic threats are not useful. Who specifically would target your organisation? Financially motivated criminals, insider threats, competitors, or state-sponsored actors? The answer changes everything — including which vendors are relevant.

What does your current security posture look like?

Conduct or commission a basic security assessment before procurement. Without knowing your current gaps, you cannot evaluate whether a vendor's offering addresses them. You will be buying based on marketing, not need.

What regulatory obligations apply to you?

PECA 2016 (and 2025 amendments), PTA regulations, sector-specific requirements (SBP for financial institutions, SECP for listed companies), and any ISO 27001 or GDPR obligations if you handle international data. These determine non-negotiable baseline requirements.

Procurement Principle

Shortlist three to five vendors based on a clear set of requirements — then narrow through comprehensive evaluation. Never enter procurement without documented requirements. Without them, vendors will define your needs for you — in their favour.

UNDERSTANDING THE MARKET

Step 2 — Know the Different Types of Provider

2

Not All Cybersecurity Providers Are the Same

Conflating provider types leads to mismatched expectations and failed engagements.

Product Vendor

Sells cybersecurity software or hardware — firewalls, endpoint protection, SIEM platforms, etc. You own the tool; you are responsible for deploying and operating it. Requires your own technical team to get value.

Key Questions

- Do you have internal capacity to operate this tool?
- Is training and onboarding included?
- What does ongoing support cost after year one?

MSSP — Managed Security Service Provider

Delivers ongoing security monitoring, detection, and response through a remote SOC. Operates under SLAs. Responsible for continuous coverage. The right choice when you lack the internal team for 24/7 operations.

Key Questions

- What are the SLA response times for critical incidents?
- Is the SOC local or offshore? What are the language/timezone implications?
- How many analysts monitor your environment at any time?

VAR — Value-Added Reseller / System Integrator

Supplies, configures, and integrates security products from multiple vendors. Should add genuine expertise — not just box-shifting. Authorised partner status with OEM vendors is the key differentiator from a generic reseller.

Key Questions

- Are they an authorised partner of the vendors they sell?
- Can they provide post-sale implementation, not just supply?
- Do they have certified engineers for the products they sell?

Consulting / Advisory Firm

Provides strategic advice, assessments, roadmaps, and governance support without necessarily delivering managed services or selling products. Useful for strategy, architecture, and compliance — but verify they can execute, not just advise.

Key Questions

- Do they have implementation case studies, not just advisory ones?
- Are recommendations product-agnostic or tied to vendor partnerships?
- What happens after the assessment report is delivered?

THE EVALUATION FRAMEWORK

Steps 3–8 — The Eight Criteria That Actually Matter

Most vendor evaluations fail because they focus on the wrong signals — slick demos, impressive logos, and checkbox compliance. These eight criteria focus on what actually predicts whether a provider will protect your organisation.

3

Technical Credentials & Certifications

Certifications are the minimum baseline — not the finish line. They confirm a provider meets a defined standard. But which certifications, for which products, verified how recently?

ISO 27001 certification

Confirms the vendor manages their own security to an internationally recognised standard. Demand the certificate, not just the claim.

OEM Authorised Partnership

For resellers and integrators — authorised partner status with vendors like Fortinet, Palo Alto, Dell, Lenovo, or NexaVM confirms certified engineers and direct vendor support access. Ask for partner certificates.

Engineer certifications

CISSP, CISM, CEH, or vendor-specific certs (Fortinet NSE, Cisco CCSP, etc.) on the team that will actually work on your account.

4

Local Presence & Response Capability

Cybersecurity is not a product you buy and forget. When an incident occurs, response time is measured in minutes — not days. Physical presence in Pakistan is not optional for managed security services.

Local SOC or response team

Does the provider have analysts physically present in Pakistan? Offshore-only SOC teams face timezone delays and may lack context for local threat actor TTPs.

Incident response SLA

What is the contractually guaranteed response time for a critical incident? Ask for the SLA document — not a verbal commitment.

Reference accounts in Pakistan

Ask for two to three local client references in organisations similar to yours. Call them. Ask specifically about incident response.

5**Supply Chain & Product Authenticity**

Pakistan's reliance on imported hardware and software creates a significant supply chain risk. Counterfeit networking equipment, unlicensed software, and grey-market hardware have all been found in Pakistani enterprise environments — creating hidden vulnerabilities and compliance exposure.

Authorised distribution chain

Demand proof of authorised distributor status. Genuine Dell, Lenovo, Fortinet, or Cisco products procured through authorised channels carry manufacturer warranty, receive security patches, and are not tampered hardware.

Licence verification

Software licences must be verifiable directly with the vendor. Many organisations in Pakistan are running unlicensed security software — which does not receive updates and may itself contain vulnerabilities.

Hardware integrity

For critical infrastructure, request tamper-evident packaging and consider supply chain verification services for high-value equipment.

6**Security Posture of the Provider Themselves**

A cybersecurity provider that has poor security practices is a liability, not an asset. With 35.5% of breaches now originating from third-party access, your provider is part of your attack surface.

External security rating

Run the vendor through an external assessment tool (SecurityScorecard, BitSight). A provider with a poor external security rating should be disqualified regardless of their certifications.

Access control practices

How does the vendor manage privileged access to your environment? Multi-factor authentication, just-in-time access, and full audit logging are non-negotiable for any provider with system access.

Breach history

Has the vendor experienced a breach? How did they respond? A past breach handled transparently and professionally is less concerning than a provider who has never disclosed incidents.

7**Contractual Clarity & Data Sovereignty**

The contract determines what actually happens when things go wrong. Most procurement failures involve perfectly capable technology and poorly written contracts.

Data residency

Where is your data stored and processed? For public sector and regulated organisations in Pakistan, data must remain within jurisdictional boundaries. Demand explicit contractual commitment — not a verbal assurance.

Incident notification obligations

What are the provider's obligations when a breach occurs? How quickly must they notify you? What evidence must they preserve? These must be contractual, not aspirational.

Exit provisions

How do you get your data back if you terminate the contract? What is the transition period? A provider that makes exit difficult is a provider to avoid entering.

8**Transparency & Honest Communication**

The most important long-term predictor of a successful provider relationship is whether they tell you the truth — including when it is uncomfortable. Evaluate this during the procurement process itself.

Proposal specificity

Does the proposal address your specific requirements, or is it a generic brochure with your logo added? Vague proposals indicate a vendor who has not understood — or has not tried to understand — your situation.

Pricing transparency

Are all costs visible upfront, including implementation, training, support, renewal, and per-user or per-device fees? Hidden costs discovered post-contract are a sign of a transactional, not partnership, relationship.

References on demand

A provider who hesitates to provide references, or who provides only references they have clearly coached, is signalling something. Ask for references from clients who experienced incidents, not just happy clients.

VENDOR RED FLAGS

Ten Red Flags That Should Disqualify a Vendor

These are observable signals — things you can see during the procurement process itself — that predict poor performance, dishonesty, or risk. If you observe any of these, proceed with extreme caution or walk away.

- 1 They cannot provide a reference account in Pakistan or the region.**

Local experience is not optional for providers of managed security services. Theoretical knowledge of global threats does not substitute for understanding the specific threat landscape, regulatory environment, and operational context you operate in.
- 2 Their proposal is generic — your name could be swapped for any other client.**

A provider who has not tailored their proposal to your specific requirements, sector, and threat profile has not listened. This predicts the same behaviour post-contract.
- 3 They cannot explain what they actually do when an incident occurs.**

Ask for a walk-through of their incident response process. Who calls you? When? What do they do in the first 15 minutes? Vague answers or buzzword-heavy non-responses indicate a team that has never actually responded to an incident.
- 4 They push products before understanding your environment.**

Any provider who leads with a product recommendation before conducting even a basic assessment of your environment is selling, not advising. The right solution depends entirely on your specific situation.
- 5 They cannot produce proof of authorised partner status with the OEM vendors they sell.**

Grey-market hardware and unlicensed software are real risks in Pakistan's market. Authorised partner certificates are verifiable directly with the manufacturer. Demand them.
- 6 Their pricing seems implausibly low.**

Cybersecurity delivered below market rates is either stripped of the components that make it effective, or subsidised by practices you do not want (data harvesting, non-genuine products, offshore labour with no local accountability).
- 7 They are evasive about data residency and storage.**

Where your data is stored is a legal and sovereignty question, not a technical preference. Any evasion on this point during pre-contract discussions should be treated as a serious warning signal.

8 Their own security posture is poor.

Run an external security assessment on the vendor before engagement. A provider whose own systems are poorly secured is demonstrably incapable of protecting yours.

9 They have no documented SLA with financial consequences for breach.

Verbal commitments about response times are worthless. If a provider is unwilling to commit to response time SLAs with financial penalties for non-performance, their commitments are aspirational — not operational.

10 They resist exit provisions or transition support clauses.

A provider who is confident in their quality welcomes clear exit provisions. A provider who resists them is aware they may not be able to retain you on merit — and is building lock-in instead.

EVALUATION TOOLS

The Vendor Scoring Matrix

Use this matrix to score each vendor consistently across the criteria that matter. Score each criterion 1–5, multiply by the weight, and compare totals. This removes subjectivity and ensures your decision is defensible.

Criterion	Weight	Score (1–5)	Weighted Score	Key Evaluation Questions
Technical Certifications & Credentials	15%			ISO 27001? OEM authorised partner certs? Engineer certifications?
Local Presence & Incident Response	20%			SOC location? SLA response times? Local references?
Supply Chain Integrity	15%			Authorised distributor? Licence verification? Hardware integrity?
Provider Security Posture	10%			External security rating? Access controls? Breach history?
Contractual Clarity & Data Sovereignty	15%			Data residency commitment? Incident notification SLA? Exit provisions?
Technical Capability Depth	10%			Architecture review? Lab environment? Proof of concept offered?
Transparency & Communication	10%			Proposal specificity? Pricing transparency? Reference quality?
Value & Commercial Terms	5%			Total cost of ownership? Hidden fees? Payment flexibility?
TOTAL	100%			

How to Use This Matrix

Score independently. Have multiple stakeholders score vendors separately, then compare and discuss disagreements. Consensus built through evidence is more reliable than consensus built through deference.

Adjust weights for your context. If your organisation has strict data sovereignty requirements, increase the Contractual Clarity weight. If you lack internal SOC capacity, increase Local Presence weight. The weights above are a starting point.

Document your evidence. For each score, record what evidence supported it — the reference call, the certificate, the SLA document. This makes the decision auditable and protects procurement officers.

PROCUREMENT CHECKLIST

The Essential RFP Checklist & Questions to Ask

What Your RFP Must Include

A Request for Proposal is not a sales enquiry. It is a legally significant document that defines the basis of your evaluation. These elements are non-negotiable.

RFP Must-Haves

- ✓ Clear description of your current environment — network topology, key systems, user count, cloud vs on-premise
- ✓ Defined scope of work — exactly what you are procuring, with explicit boundaries of what is excluded
- ✓ Compliance requirements — PECA, PTA, SBP, SECP, ISO 27001, or sector-specific frameworks that apply
- ✓ Data residency requirements — where data must be stored and processed, and under whose jurisdiction
- ✓ Response time SLA requirements — expected response times for P1/P2/P3/P4 incident categories
- ✓ Technical requirements — specific capabilities, integration requirements, and technology stack compatibility
- ✓ Reporting requirements — frequency, format, and content of security reports expected
- ✓ Evaluation criteria and weightings — published in the RFP so all vendors know how they will be judged
- ✓ Reference requirement — minimum two verifiable local client references required
- ✓ Proof of authorised partner status — required for all OEM products proposed
- ✓ Total cost of ownership breakdown — year 1 and year 3 costs, including all fees
- ✓ Exit and transition provisions — how engagement terminates, data return process, transition period

Questions Every Procurement Decision-Maker Must Ask

Ask these verbally, in vendor presentations, and require written responses. How a vendor answers these questions is as important as what they answer.

Operations & Incident Response

“Walk me through exactly what happens in the first 15 minutes of a ransomware incident affecting one of your managed clients.”

“How many clients does each SOC analyst manage? What is the escalation path when they are overloaded?”

“Can you provide the incident response report from a real engagement — anonymised?”

“What is your contractual response time for a P1 critical incident, and what happens if you miss it?”

Credentials & Supply Chain

“Show me your current OEM authorised partner certificate for [product you are proposing].”

“How can I verify the authenticity of the hardware you are supplying directly with the manufacturer?”

“Which of your engineers hold active certifications for the specific products you are deploying for us?”

“What is your software licence management process — how do you ensure we are always running licensed, updated software?”

Data & Contract

“Show me the specific clause in your standard contract that commits to data residency in Pakistan.”

“What happens to our data if we terminate the contract? What is the format and timeline for return?”

“If you experience a breach affecting our data, what is your contractual notification obligation and timeline?”

“Can you provide your standard SLA document before we proceed to proposal stage?”

Pakistan-Specific

“Who are two clients in Pakistan in organisations similar to ours that we can speak to directly?”

“Do you have a local NOC or SOC with analysts physically based in Pakistan?”

“Are you registered with PSEB (Pakistan Software Export Board) or PTA as applicable to your services?”

“How many engineers on the team that will work on our account are Pakistan-based?”

PAKISTAN CONTEXT

Critical Considerations Specific to Pakistan

The general principles of cybersecurity procurement apply globally. But Pakistan has specific structural factors that materially affect what good procurement looks like in this market — and what risks are heightened.

Supply Chain Integrity Is a Real Risk

Pakistan is almost entirely dependent on imported IT hardware, software, and services. Counterfeit networking equipment and unlicensed software have been identified in enterprise and government environments. The impact is not just financial — grey-market hardware may contain hardware-level vulnerabilities, and unlicensed software does not receive security updates. Always procure through authorised channels and verify authenticity directly with manufacturers.

Regulatory Landscape Is Evolving Rapidly

PECA 2016 and its 2025 amendments, PTA regulations, SBP cybersecurity circulars for financial institutions, and the emergence of NCERT all create a shifting regulatory baseline. Your provider must understand these requirements — not just international frameworks like ISO 27001 or NIST — and be able to help you meet local obligations. Verify that your provider is actively tracking Pakistani regulatory developments.

Cybersecurity Is Not Yet in the Procurement Process

Research consistently finds that cybersecurity requirements are not embedded in standard IT procurement processes in Pakistan. This means organisations are buying hardware and software without considering the security implications — and vendors are not being evaluated on security credentials. Use this guide to change that in your organisation. Security requirements belong in every IT procurement, not just dedicated cybersecurity procurement.

Pakistan Ranks 14th in Asia-Pacific for Cyber Vulnerabilities

The threat level is not theoretical. DDoS attacks on government infrastructure, ransomware targeting financial institutions, BEC fraud, and state-sponsored espionage are all documented in the Pakistani threat landscape. The HeartSender phishing group based in Pakistan caused \$3 million in losses internationally in 2025. The threat environment demands capable, locally-aware security providers — not international products with no local support.

Local Support and Response Time Matter More Here

In markets with mature cybersecurity ecosystems, remote SOC services are standard. In Pakistan, timezone alignment, language, understanding of local threat actors, and physical presence for incident response are material differentiators. An offshore SOC that responds at 3am Pakistan time to an incident that began at 11pm is not the same as a local team available immediately. Weight local presence accordingly.

SUMMARY

The Eight Principles of Smart Cybersecurity Procurement

1

Define requirements before approaching vendors.

Without documented requirements, vendors define your needs for you.

2

Understand what type of provider you actually need.

MSSP, VAR, product vendor, and consulting firm are different things.

3

Verify certifications — don't just accept the claim.

ISO 27001, OEM authorised partner status, and engineer certifications are all verifiable.

4

Weight local presence and incident response capability heavily.

In Pakistan's market, who shows up when something goes wrong is the most important question.

5

Demand supply chain integrity — especially for hardware.

Procure through authorised channels. Verify authenticity directly with manufacturers.

6

Assess the provider's own security posture.

Your provider is part of your attack surface. A poorly secured provider is a liability.

7

Get everything material in the contract.

SLAs, data residency, incident notification, exit provisions. Verbal commitments are worthless.

8

Watch for red flags during the procurement process itself.

How a vendor behaves before the contract predicts how they will behave after it.

DAQAI PRIVATE LIMITED**About This Guide**

This guide was produced by DAQAI Private Limited — an enterprise IT solutions and cybersecurity services company headquartered in Islamabad, Pakistan. We help organisations secure their environments, modernise their infrastructure, and navigate complex technology procurement decisions.

We are authorised partners for Dell Technologies, Lenovo 360, NexaVM, and SGBox, and resellers and integrators for 55+ global technology vendors including Fortinet, Palo Alto, CrowdStrike, Akamai, Recorded Future, Tenable, and more.

If you would like a complimentary consultation on your organisation's cybersecurity posture or procurement process, our team is available to help.

www.daqai.org | contact@daqai.org | +92 321 5487114

Islamabad, Pakistan | Systems you can trust

© 2026 DAQAI Private Limited. All rights reserved. This guide is provided for informational purposes. Reproduction with attribution permitted.